

Compliance Analysis of the Department of Defense Vulnerability Disclosure Program Policy

Scope

Policy section, Commitment(Legal) Section, Out of Scope Section, and classification rules on “Valid” versus “Duplicate” and/or “Informational” findings.

Safe Harbor

When a security researcher works in accordance with the terms and conditions of the VDP program, the DoD will protect researchers from legal action by:

- “...not initiate or recommend any law enforcement action or civil lawsuits related to such activities against the researcher, and...”
- “...inform the pertinent law enforcement agencies or civil plaintiffs that the researchers activities were, to the best of the our knowledge, conducted pursuant to, and in compliance with the terms and conditions of the program.”

The “Kill Switch”

“Out of Scope” activities that are strictly forbidden include, but aren’t limited to:

- Attacks against physical facilities
- Social engineering attacks (e.g., phishing, opening support requests)
- Issues where testing may affect the availability of systems

Verification

The DoD defines a “Valid” finding as a reproduceable and confirmed vulnerability that requires remediation, whereas a “Duplicate” finding is one that reports on a previously submitted vulnerability, and an “Informational” finding is one that may be helpful but does not support a vulnerability that needs remediation.